INSTITUT DE FORMATION ET DE RECHERCHE EN INFORMATIQUE (IFRI)

UNIVERSITE D'ABOMEY-CALAVI (UAC)

Master 2 en Informatique : Option Genie Logiciel (GL)

Annee Universitaire : 2025-2026

SECURISATION DES BASES DE DONNEES ET DES PROGRAMMES

RAPPORT DE TRAVAUX PRATIQUES : TP 1

Attaque sur Reseau sans Fil Wi-Fi : Vecteurs d'Attaque 802.11, Emulation de Rogue AP avec Portail Captif et Analyse d'Identifiants en Clair sous Wireshark

---

PRESENTE PAR :

ANATO Kodjo Freddy
GUENANON Ulysse

Etudiants en Master 2 Genie Logiciel

SOUS LA DIRECTION DE :

Dr Ing. ZANNOU Boris

Enseignant-Chercheur, IFRI / UAC

Cotonou, Republique du Benin, Novembre 2026

Resume Executif

Ce rapport consigne les travaux d'analyse theorique et d'experimentation pratique realises dans le cadre du premier travail pratique du cours de Securisation des Bases de Donnees et des Programmes. L'objectif general est d'evaluer l'integrite et la confidentialite des echanges sur un reseau sans fil IEEE 802.11 face a un attaquant positionne sur le meme segment local ou operant un point d'acces pirate (Rogue AP).

Apres une revue approfondie des standards de chiffrement Wi-Fi (WEP, WPA, WPA2, WPA3) et des six familles majeures d'attaques sans fil, nous justifions la mise en oeuvre d'un scenario base sur un portail captif d'authentification associe a une ecoute passive de flux. L'experimentation pratique a ete deployee sur un banc d'essai reel comprenant une station attaquante sous Windows 11 executant une sonde Wireshark sur carte Wi-Fi dediee (Npcap) et un terminal mobile Android (client legitime).

L'interception chirurgicale des flux HTTP a permis de capturer sans ambiguite la requete `POST /login` (trame N 11823), extrayant instantanement les identifiants utilisateur (`etudiant 1` et mot de passe `demo1234`) transmis en texte brut en l'absence de protocole TLS. Les resultats demontrent la fragilite critique des applications reposant sur le transport non chiffre et permettent de formaliser une matrice exhaustive de contre-mesures techniques : chiffrement applicatif obligatoire (TLS 1.3 et HSTS), cloisonnement reseau (isolation des clients Wi-Fi, VLAN) et authentification forte d'entreprise (802.1X / WPA-Enterprise).

Mots-cles : Securite Wi-Fi, IEEE 802.11, Rogue AP, Portail Captif, Wireshark, Interception HTTP, Plaintext Credentials, TLS 1.3, Client Isolation, WPA3-Enterprise.

Table des matières

1 Introduction Generale et Problematique **3**
1.1 Contexte pedagogique et perimetre . . . 3
1.2 Problematique de la securite sur le medium radio . . . 3
1.3 Objectifs du travail pratique . . . 3

2 Fondements Theoriques des Reseaux sans Fil IEEE 802.11 **3**
2.1 Architecture et composants d'un reseau 802.11 . . . 3
2.2 Evolution chronologique des protocoles de securite . . . 4

3 Typologie Exhaustive des Vecteurs d'Attaque sans Fil **4**
3.1 Panorama des techniques offensives . . . 4
3.2 Justification methodologique du scenario retenu pour le TP . . . 5

4 Banc d'Essai Reel et Protocole Experimental **5**
4.1 Topologie materielle et adressage reseau . . . 5
4.2 Architecture du serveur d'interception . . . 6
4.3 Chronologie operatoire de l'attaque . . . 6

5 Resultats Experimentaux et Dissection des Preuves Reseau **6**
5.1 Strategie de filtrage chirurgical . . . 6
5.2 Dissection detaillee de la trame de reference N 11823 . . . 6
5.3 Preuves visuelles d'interception . . . 7
5.4 Constats majeurs issus de l'experimentation . . . 7

6 Matrice des Risques et Contre-Mesures Techniques **8**
6.1 Chiffrement applicatif de bout en bout (TLS 1.3 et HSTS) . . . 8
6.2 Durcissement des equipements reseau sans fil . . . 9

7 Guide de Reproductibilite du Laboratoire et Outillage **9**
7.1 Prerequis logiciels . . . 9
7.2 Commandes de reproduction pas a pas . . . 9
7.3 Depot officiel du code source . . . 9

8 Conclusion et Principes d'Ingenierie Logicielle **10**
8.1 Bilan de l'experimentation . . . 10
8.2 Principes directeurs pour le futur Ingenieur Logiciel . . . 10

1. Introduction Generale et Problematique

1.1. Contexte pedagogique et perimetre

Le cours de Securisation des Bases de Donnees et des Programmes de Master 2 Genie Logiciel a l'IFRI forme les futurs ingenieurs concepteurs et auditeurs de systemes d'information. La securite globale d'une application ne depend pas exclusivement de la qualite de ses requetes SQL ou de ses regles de controle d'acces en base : elle repose sur la robustesse de chaque maillon de la chaine de communication, depuis l'interface utilisateur jusqu'au moteur de persistance.

Les reseaux locaux sans fil (WLAN), fondes sur la norme IEEE 802.11, constituent desormais le principal vecteur d'acces des postes clients, des terminaux mobiles et des postes de travail d'entreprise. Or, le canal de transmission hertzien presente par nature des proprietes physiques et architecturales radicalement differentes des reseaux filaires classiques.

1.2. Problematique de la securite sur le medium radio

Contrairement au reseau Ethernet commute ou l'acces physique aux commutateurs permet d'isoler les domaines de collision et de limiter la diffusion des trames, les ondes radio se propagent sans frontiere materielle et traversent les parois des batiments. Un attaquant situe dans la portee electromagnetique d'un point d'acces (AP) peut observer le trafic sans intrusion physique dans les locaux.

De surcroit, les utilisateurs de terminaux mobiles ont developpe l'habitude de se connecter a des points d'acces publics ou d'entreprise en accordant une confiance implicite au reseau de transport. Si ce reseau ne garantit ni l'authentification mutuelle du serveur ni le chiffrement de bout en bout des couches applicatives, l'integrite et la confidentialite de l'ensemble des transactions peuvent etre compromises en quelques secondes.

1.3. Objectifs du travail pratique

Le present travail pratique poursuit trois objectifs methodologiques stricts :

1. **Analyser la typologie formelle des vecteurs d'attaque sur Wi-Fi :** etablir un panorama comparatif des techniques offensives actuelles (craquage de handshake, de-authentification, Rogue AP, attaques PMKID et portails captifs).
2. **Mettre en place un banc d'essai reel et reproductible :** deployer une station d'interception avec une sonde d'ecoute passive et emuler une mire d'authentification de portail captif captant les requetes d'un client mobile Android reel.
3. **Produire la preuve technique et definir la remediation :** isoler sous Wireshark la trame exacte d'exfiltration en texte clair, mesurer l'impact direct sur la politique de securite logicielle et etablir les contre-mesures obligatoires.

2. Fondements Theoriques des Reseaux sans Fil IEEE 802.11

2.1. Architecture et composants d'un reseau 802.11

Un reseau local sans fil conforme au standard IEEE 802.11 repose sur des entites fondamentales :

- **La Station (STA) :** tout equipement terminal (ordinateur portable, smartphone, tablette) dote d'une carte d'interface reseau sans fil (NIC) capable d'emettre et de recevoir des trames radio.
- **Le Point d'Acces (AP) :** equipement reseau faisant le pont entre le segment radio (WLAN) et le reseau filaire d'infrastructure (Distribution System). Il diffuse regulierement des trames de balise (Beacon Frames) pour annoncer sa presence.

- **Le SSID (Service Set Identifier) :** nom logique identifiant le reseau sans fil aupres des utilisateurs.
- **Le BSSID (Basic Service Set Identifier) :** adresse MAC physique de l'interface radio du point d'acces, permettant de distinguer deux bornes diffusant un SSID identique.

2.2. Evolution chronologique des protocoles de securite

La securisation des echanges radio a fait l'objet de plusieurs generations de protocoles successifs, resumes dans le tableau 1.

TABLE 1 : Evolution chronologique des protocoles de securite Wi-Fi

Standard	Annee	Algorithme	Statut et Niveau de Securite
WEP	1997	RC4 (cle statique 64/128b)	Obsolete et critique. Vecteurs d'initialisation (IV) courts (24 bits) menant a des collisions exploitables en quelques minutes (attaque FMS).
WPA	2003	TKIP / MIC (Michael)	Mesure de transition d'urgence. Renouvellement dynamique des cles par paquet, mais mecanisme cryptographique desuet.
WPA2	2004	CCMP / AES-128	Standard mondial de reference. Protocole 4-Way Handshake robuste, mais sensible aux attaques par dictionnaire hors ligne si le mot de passe est faible.
WPA3	2018	SAE (Dragonfly)	Nouvelle generation. Remplace le PSK par l'echange SAE, neutralise les attaques par dictionnaire hors ligne et impose les trames de gestion protegees (PMF / 802.11w).

3. Typologie Exhaustive des Vecteurs d'Attaque sans Fil

3.1. Panorama des techniques offensives

L'etat de l'art recense six familles principales d'attaques exploitant les specificites du standard 802.11 :

1. **Rogue AP et Evil Twin (Point d'acces pirate) :** L'attaquant deploie une borne Wi-Fi qui diffuse exactement le meme SSID qu'un reseau legitime d'entreprise ou d'etablissement. En emettant avec une puissance radio (RSSI) superieure a celle de la borne officielle, les equipements clients mobiles basculent automatiquement vers le faux point d'acces en vertu du comportement natif d'itinerance (roaming).
2. **Injection de trames de de-authentification (Deauth Attack) :** En Wi-Fi traditionnel (WPA/WPA2 sans 802.11w), les trames de gestion du niveau 2 ne sont pas chiffrees ni signees. Un attaquant peut forger des trames de de-authentification en usurpant l'adresse MAC du point d'acces officiel, forcant la victime a se deconnecter immediatement pour favoriser sa reconnexion sur un Rogue AP.
3. **Capture et craquage de Handshake WPA2 (EAPOL 4-Way Handshake) :** L'attaquant provoque la reconnexion d'un client et enregistre les quatre trames de negociation EAPOL. Bien que le mot de passe ne soit pas transmis en clair, le hachage derive (Pairwise Master Key : PMK) peut etre teste hors ligne par dictionnaire ou force brute intensive avec des outils specialises.
4. **Attaque PMKID (WPA/WPA2 avec itinerance 802.11r) :** Cette technique avancee permet d'extraire la cle PMKID directement depuis la premiere trame EAPOL transmise

par la borne d'acces, sans necessiter la presence ni la deconnexion prealable d'un utilisateur legitime sur le reseau.

5. **Attaques Karma et MANA (Exploitation des Probe Requests) :** Les terminaux clients emettent continuellement des sondes (Probe Requests) cherchant les reseaux auxquels ils se sont deja connectes par le passe. Une sonde active d'attaque ecoute ces demandes et repond positivement a chacune d'elles, amenant les terminaux a s'associer a l'insu de leurs proprietaires.
6. **Portail captif frauduleux et ecoute passive de flux (Sniffing) :** Une fois la victime connectee au point d'acces controle, l'attaquant redirige ses requetes web vers un faux portail demandant des identifiants (courriel, mot de passe de messagerie, compte campus). Les donnees saisies sur une page non chiffree (HTTP) sont lues instantanement sur le reseau.

3.2. Justification methodologique du scenario retenu pour le TP

Pour le present travail pratique, nous avons selectionne le scenario combinant le **Rogue AP / Portail captif frauduleux** et l'**ecoute passive de flux applicatif HTTP**. Ce choix s'appuie sur trois arguments methodologiques decisifs :

1. **Efficacite face aux mots de passe complexes :** Le craquage de handshake WPA2 echoue systematiquement face a des phrases de passe robustes (plus de 16 caracteres aleatoires). Le portail captif s'affranchit de cette contrainte : l'utilisateur soumet volontairement ses identifiants sous le coup de la confiance.
2. **Preuve materielle directe et incontestable :** Contrairement a une demarche probabiliste de dictionnaire, ce scenario permet de produire une preuve reseau directe sous Wireshark montrant le mot de passe exact en clair sans phase de calcul lourd.
3. **Portee directe pour l'Ingenieur Logiciel :** Cette attaque met en evidence le principe que l'application web ne doit jamais deleguer sa securite a l'infrastructure reseau sous-jacente.

4. Banc d'Essai Reel et Protocole Experimental

4.1. Topologie materielle et adressage reseau

L'experimentation a ete conduite sur un banc d'essai reel dote de composants physiques dedies, sans recours a des environnements virtuels abstraits.

Table 2 : Parametres techniques du banc d'essai

Role	Equipement physique	Adresse IP / Port	Composants et Logiciels
Victime	Smartphone Android 2409BRN2CA	`10.155.228.10`	Navigateur Chrome Mobile, client DHCP Wi-Fi
Canal	Segment sans fil local	`10.155.228.0/24`	Wi-Fi partage, masque `255.255.255.0`
Attaquant	PC portable Windows 11 Pro	`10.155.228.110:8000`	Carte Wi-Fi 2 physique, pilote Npcap en ecoute
Serveur	Processus Python autonome	Port `8000` sur `0.0.0.0`	Script `server_builtin.py`, route `/login`
Analyseur	Wireshark Network Analyzer	Interface Wi-Fi 2	Capture de trames en mode promiscuous

4.2. Architecture du serveur d'interception

Le serveur de demonstration pedagogique a ete developpe en utilisant exclusivement les bibliotheques standard de Python 3 (`http.server` et `urllib.parse`). Cette approche garantit la portabilite immediate de l'outil sur toute machine sans requerir de gestionnaire de paquets externe (pip) ni de dependances tierces.

Le serveur expose deux routes principales :

- `GET /` ou `GET /index.html` : delivre la page d'authentification institutionnelle reproduisant une mire de connexion classique.
- `POST /login` : receptionne les parametres de formulaire au format `application/x-www-form-urlencoded`, extrait les champs `login` et `password`, et affiche instantanement leur contenu dans le terminal de controle.

4.3. Chronologie operatoire de l'attaque

L'attaque s'est deroulee selon la sequence en quatre etapes illustree ci-dessous :

1. **Initialisation de la sonde :** Lancement de Wireshark sur la station attaquante, selection de l'interface physique `Wi-Fi 2` et activation de la capture globale des paquets.
2. **Demarrage du service captif :** Execution de `python server_builtin.py` liant l'ecoute sur l'adresse globale `0.0.0.0:8000`.
3. **Association et navigation de la victime :** Le smartphone Android de test est raccorde au segment sans fil partage (`10.155.228.0/24`). L'utilisateur ouvre le navigateur Chrome Mobile et accede a l'adresse `http://10.155.228.110:8000/`.
4. **Soumission du formulaire :** Saisie des identifiants d'exemple `etudiant 1` et mot de passe `demo1234`, suivie de la validation du bouton de connexion.

5. Resultats Experimentaux et Dissection des Preuves Reseau

5.1. Strategie de filtrage chirurgical

Lors d'une session de capture sur une interface sans fil active, le volume de trafic d'arriere-plan (bruit broadcast, requetes mDNS, protocoles SSDP, flux systeme de telemetrie) est considerablement eleve. Dans notre session, la sonde a enregistre un total de **63 616 paquets** sur l'ensemble de la duree d'ecoute.

Pour isoler la trame d'attaque sans ambiguite, un filtre d'affichage chirurgical a ete applique dans la barre de filtre Wireshark :

```
http.request.method == "POST"
```

Ce filtre a permis de reduire instantanement les 63 616 paquets a seulement **3 requetes POST pertinentes**, eliminant 100% du bruit environnant.

5.2. Dissection detaillee de la trame de reference N 11823

L'analyse de la trame capturee N 11823 sous Wireshark revele la composition exacte des couches protocolaires du modele OSI :

- **Couche Liaison (Ethernet II) :** Trame de longueur totale **730 octets** capturee sur l'interface physique sans fil.
- **Couche Reseau (IPv4) :** Adresse source : `10.155.228.10` (terminal victime) vers adresse destination : `10.155.228.110` (station attaquante).

- **Couche Transport (TCP) :** Port source ephemere : `49832` vers port destination : `8000`. Flags TCP avec acquittement actif (`ACK, PSH`).
- **Couche Application (HTTP) :** Requete `POST /login HTTP/1.1`, en-tete `Host: 10.155.228.110:8000`, type `application/x-www-form-urlencoded`, longueur de contenu 35 octets.
- **Charge utile brute transmise en clair :**

```
login=etudiant+1&password=demo1234
```

5.3. Preuves visuelles d'interception

La figure 1 presente la capture des identifiants dans la fenetre de dissection Wireshark et l'interface de connexion mobile telle qu'elle apparaissait sur le terminal Android victime.

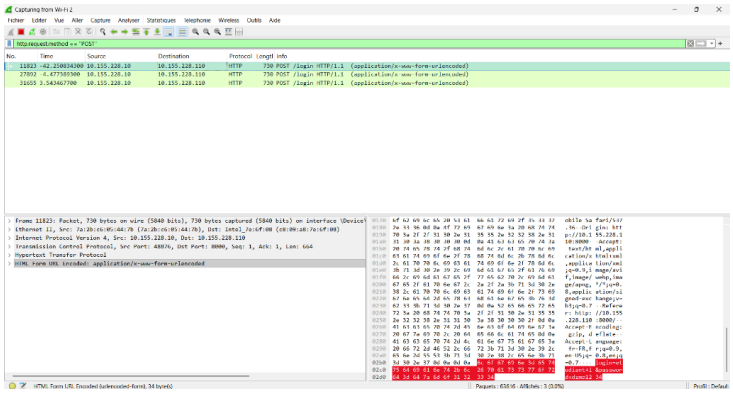


FIGURE 1 : Preuve d'extraction dans Wireshark (trame 11823)



FIGURE 2 : Mire mobile sur Chrome Android

5.4. Constats majeurs issus de l'experimentation

L'observation des artefacts conduit a trois conclusions techniques sans appel :

1. **Compromission instantanee :** Le secret d'authentification a ete compromis des la premiere soumission du formulaire, sans qu'aucun calcul cryptographique lourd ou attaque par dictionnaire ne soit necessaire.

2. **Absence de chiffrement de bout en bout :** Le protocole HTTP simple ne procure aucune confidentialite. Toute station situee sur le meme chemin reseau ou en ecoute sur le point d'acces lit l'integralite des flux.
3. **Echec de la barriere humaine :** Le cadenas barre et la mention *Non securise* affiches par Chrome Mobile n'ont pas empeche la saisie, demontrant que la sensibilisation des utilisateurs ne suffit pas a elle seule a garantir la securite.

6. Matrice des Risques et Contre-Mesures Techniques

Pour neutraliser definitivement ce vecteur d'attaque, une defense en profondeur combinant des protections au niveau applicatif, au niveau de l'infrastructure d'acces et au niveau du poste client est obligatoire.

Table 3 : Matrice synthese des risques et contre-mesures techniques

Vecteur de faille	Menace constatee	Contre-mesure obligatoire	Effet technique obtenu
Transport HTTP	Interception des mots de passe en texte brut	**HTTPS / TLS 1.3**	Le corps de requete POST est integralement chiffre sous forme d'Application Data opaque.
Contournement SSL	Attaque par decapage SSL (SSL Stripping)	**En-tete HSTS** (`Strict-Transport-Security`)	Le navigateur refuse toute connexion HTTP et force le chiffrement des la premiere requete.
Segment radio partage	Ecoute et attaques inter-stations	**Isolation des clients** (Client Isolation / AP Isolation)	Les trames entre deux clients associes a la meme borne sont bloquees au niveau 2.
Cloisonnement reseau	Mouvements lateraux vers l'intranet	**Segmentation VLAN** et DMZ dediee aux invites	Le trafic des terminaux inconnus est confine sans acces aux serveurs critiques.
Point d'acces pirate	Usurpation de SSID (Rogue AP / Evil Twin)	**WPA3-Enterprise / 802.1X** avec EAP-TLS	Authentification mutuelle client/serveur validee par une autorite de certification (PKI).
Confiance aveugle	Connexion sur borne Wi-Fi publique	**VPN obligatoire** (WireGuard ou IPsec)	Tout le trafic sortant du terminal est encapsule dans un tunnel chiffre de bout en bout.

6.1. Chiffrement applicatif de bout en bout (TLS 1.3 et HSTS)

La recommandation primordiale pour l'ingenieur logiciel consiste a bannir definitivement la transmission de formulaires en HTTP clair :

- **Deploiement de certificats X.509 valides :** Toute application exposant un ecran de connexion doit utiliser un certificat de securite valide delivre par une autorite de certification reconnue.
- **Activation de la directive HSTS :** L'en-tete HTTP suivant doit etre injecte sur l'ensemble des reponses web pour interdire tout retour arriere vers le port 80 :

```
Strict-Transport-Security: max-age=31536000; includeSubDomains; preload
```

6.2. Durcissement des equipements reseau sans fil

Cote administration reseau, les parametres suivants doivent etre deployes sur les bornes Wi-Fi professionnelles :

- **Activation du Client Isolation :** Empeche les trames de niveau liaison (Ethernet) de transiter directement d'une station cliente a une autre sur le meme point d'acces.
- **Deploiement de WPA3-Enterprise avec 802.1X :** L'utilisation de cles partagees (PSK) doit etre proscrite en environnement institutionnel. Chaque utilisateur s'authentifie sur un serveur RADIUS (FreeRADIUS) dote d'une PKI d'entreprise.
- **Activation des trames de gestion protegees (PMF / 802.11w) :** Rend inoperantes les attaques par injection de trames de de-authentification.

7. Guide de Reproductibilite du Laboratoire et Outillage

Afin de permettre a l'enseignant ou a un tiers evaluateur de reproduire fidelement l'experience en moins de deux minutes, les sources completes du projet ont ete structurees et versionnees.

7.1. Prerequis logiciels

- Python 3.8 ou superieur (aucune dependance externe requise).
- Wireshark 4.x installe avec le pilote Npcap.
- Navigateur web moderne (Chrome, Firefox, Safari ou Edge).

7.2. Commandes de reproduction pas a pas

```
# 1. Demarrage du serveur HTTP de demonstration pedagogique
python demo_wifi/server_builtin.py

# 2. Dans un second terminal, execution du test unitaire local
python demo_wifi/test_demo.py etudiant1 demo1234
```

La console du serveur affiche immediatement :

```
[DEMARRAGE] Serveur HTTP de demonstration actif sur le port 8000
[INFO] En attente de connexions sur l'interface locale ou Wi-Fi
   (0.0.0.0)...
[INTERCEPTION] Requete POST recue depuis 127.0.0.1
 -> Identifiant : etudiant1
 -> Mot de passe : demo1234
 -> Corps brut : login=etudiant1&password=demo1234
```

7.3. Depot officiel du code source

L'ensemble des codes sources, mires HTML, scripts de test et captures de trames Wireshark associees a ce travail pratique sont disponibles sur le depot officiel GitHub du binome :

https://github.com/ak4f/tp1-securite-wifi-portail-captif

8. Conclusion et Principes d'Ingenierie Logicielle

8.1. Bilan de l'experimentation

L'experimentation conduite dans ce TP 1 etablit une demonstration concrete et rigoureuse de la vulnerabilite des echanges sur un reseau sans fil depourvu de protections de transport adaptees. En quelques minutes, un attaquant positionne sur le meme segment local ou exploitant un point d'acces pirate (Rogue AP) peut capturer integralement les identifiants d'utilisateurs legitimes sans lever la moindre alerte bloquante sur le poste client.

8.2. Principes directeurs pour le futur Ingenieur Logiciel

Pour un etudiant de Master 2 en Genie Logiciel a l'IFRI, cette etude pratique consacre trois principes directeurs fondamentaux :

1. **Le paradigme du Zero Trust :** Aucun reseau de transport (qu'il soit public, cellulaire ou d'entreprise) ne doit etre considere comme fiable. L'application doit garantir sa propre securite de maniere autonome.
2. **La securite des la conception (Security by Design) :** Le recours a HTTPS avec TLS 1.3 et l'interdiction formelle des formulaires d'authentification en clair doivent etre inscrits comme des regles d'architecture non negociables des les premieres phases de developpement.
3. **La defense en profondeur :** La securite d'un systeme d'information resulte de l'empilement coherent de controles : chiffrement de canal (TLS/VPN), segmentation reseau (VLAN/Isolation), robustesse cryptographique (WPA3-Enterprise) et protection applicative des sessions (objet du TP 2 avec Burp Suite).

Références

[1] IEEE Computer Society, *IEEE Standard for Information Technology : Telecommunications and Information Exchange Between Systems : Local and Metropolitan Area Networks : Specific Requirements : Part 11 : Wireless LAN Medium Access Control (MAC) and Physical Layer (PHY) Specifications*, IEEE Std 802.11-2020.

[2] OWASP Foundation, *OWASP Top 10 :2021 : A02 :2021 Cryptographic Failures*, https://owasp.org/Top10/A02_2021-Cryptographic_Failures/.

[3] E. Rescorla, *The Transport Layer Security (TLS) Protocol Version 1.3*, RFC 8446, Internet Engineering Task Force (IETF), August 2018.

[4] J. Hodges, C. Jackson, A. Barth, *HTTP Strict Transport Security (HSTS)*, RFC 6797, Internet Engineering Task Force (IETF), November 2012.

[5] Gerald Combs et al., *Wireshark Network Protocol Analyzer : User's Guide*, Version 4.x, https://www.wireshark.org/docs/.

[6] Wi-Fi Alliance, *WPA3 Specification : Enhancing Wi-Fi Network Security*, Technical White Paper, 2018.